

Augmenting Rule-Based Private-Cloud Forensic Investigation with Evidence-Grounded LLM Reasoning

Md. Nazmul Hasan

Department of Computer Science and Engineering
United International University
Dhaka, Bangladesh
mhasan2610031@mscse.uiu.ac.bd

Abstract—Private-cloud incident investigation must reconstruct activity from fragmented logs without a unified audit plane comparable to public-cloud services. Rule-based correlation is transparent and auditable but brittle when evidence is distributed across time and sources; large language models (LLMs) can synthesize such evidence, but forensic use requires claims grounded in auditable event references. This paper evaluates an evidence-grounded LLM pipeline for post-incident forensic triage: logs from seven private-cloud source types are normalized into a unified event schema, a twelve-rule engine provides a transparent baseline, and the same correlated timeline is submitted to an open-weight Gemma model that must cite an event identifier for every claim, with a seven-check validator verifying citation grounding. The corpus spans 115 scenarios across ten parameterized families: fifteen author-designed calibration scenarios on which the LLM prompt was tuned, and one hundred generator-created holdout scenarios produced from a committed parameter spec under a fixed seed to limit designer bias. On the holdout the rule baseline reaches 70.0% verdict accuracy [60.0, 78.8] and the grounded LLM 78.0% [68.6, 85.7]; the paired improvement is not significant under McNemar’s exact test ($p=0.243$). The headline is split by label: on attack scenarios the LLM reaches 100.0% [93.6, 100.0] versus 69.6% for rules ($p<0.001$), while on benign scenarios the LLM reaches only 50.0% [34.6, 65.4] versus 70.5% for rules ($p=0.064$), and on hard-benign scenarios designed to generate alert load it drops to 38.2%. Grounding strengthens at scale: 2067 of 2068 event-identifier references resolved to real events (99.95%), 114 of 115 scenarios have zero invalid citations, and only one chronology violation was observed across the entire corpus. Failure analysis shows citation grounding is not interpretive correctness: one adversarial calibration scenario yielded a correct attack verdict attributed to the decoy actor rather than the true attacker, and on benign scenarios with non-trivial alert load the LLM systematically over-classifies as attack. A 35-window replay on the third-party CERT Insider Threat Test Dataset r4.2 [1] (5 of 40 windows lost to a transient endpoint outage and reported as such; on these richer inputs the model returned Markdown rather than the requested JSON in 34 of 35 windows, from which verdicts were parsed) intensifies both observations: the LLM reaches 100% recall on all 20 labeled insider months across the three r4.2 scenarios, yet flags nearly every benign user-month (at least 13 of 15) as an incident. The results support evidence-grounded LLM reasoning as an analyst-supervised triage layer that contributes recall on subtle multi-day insider patterns rules miss — not an autonomous detector, given the false-positive rate on legitimate-but-noisy activity.

Index Terms—digital forensics, post-incident triage, private cloud, large language models, evidence grounding, hallucination mitigation, rule-based correlation, security operations

I. INTRODUCTION

Private-cloud environments — organization-controlled infrastructure operated by banks, government agencies, and other regulated organizations — generate forensic evidence across many disjoint surfaces. When an incident occurs, the analyst must reconstruct what happened from authentication logs, file-access records, administrative actions, network telemetry, database traces, web-server logs, and email metadata. Unlike public-cloud platforms, which expose unified audit services such as AWS CloudTrail, a private cloud has no single audit plane [2], [3]: the forensic problem is not absence of logs but absence of unified, correlated, investigation-ready evidence [4]. This paper concerns *post-incident forensic triage* — timeline reconstruction, evidence-chain analysis, scenario classification, and explanation over already-collected logs — not real-time intrusion detection.

The dominant industrial approach to triage is rule-based correlation, expressed in security information and event management (SIEM) platforms as threshold predicates over normalized event streams. Rules are transparent, deterministic, and auditable — essential properties in regulated settings — but brittle in two well-documented directions [5], [6]: they generate large alert volumes on legitimate-but-unusual activity (travel, maintenance), and they produce weak verdicts on attacks whose pattern lives in cross-time-window aggregation rather than in any single triggering event [7]. Large language models offer a complementary capability — synthesizing weak signals across many events, weighing contextual metadata, and producing narrative explanations [8], [9] — but an unconstrained LLM can hallucinate evidence, overclaim causality, or attribute an incident to the wrong actor [10], [11], failure modes unacceptable where every claim must be defensible in legal review.

We therefore ask a narrower question than “can an LLM detect attacks?”: *can an evidence-grounded LLM, operating*

only over structured normalized events and required to cite specific event identifiers for every claim, improve post-incident forensic triage over a transparent rule-based baseline while preserving traceability?

The evaluated system normalizes seven private-cloud log source types onto a unified event schema, reconstructs a chronologically ordered, session-grouped, cross-source-linked timeline, and submits the same evidence in parallel to a twelve-rule engine and a constrained open-weight LLM [12] whose every claim must cite input event identifiers; a deterministic seven-check validator then audits citation grounding. Privacy is treated as a deployment constraint (open weights, in-boundary serving), not as the contribution.

A. Our Contribution

- A 115-scenario private-cloud forensic triage corpus over a unified seven-source event schema, split into fifteen author-designed calibration scenarios (on which the LLM prompt was tuned) and one hundred generator-created holdout scenarios produced from a committed parameter spec under a fixed seed (`config/corpus_spec.yaml`, `generate_corpus.py`). Two calibration scenarios are designed and *retained* as adversarial failure cases.
- An evidence-grounded LLM triage pipeline with a transparent twelve-rule baseline, per-claim event-identifier citation, and a deterministic seven-check grounding validator, formalized in Section VI.
- A multi-axis statistical evaluation separating verdict accuracy, suspect/attack-chain correctness, and citation-grounding validity. Headline results are reported on the holdout with exact Clopper–Pearson 95% confidence intervals, paired McNemar’s exact test, and bootstrap (10 000 resamples) intervals on accuracy deltas, broken down by label (attack vs benign) and by family.
- An extended rule-context ablation testing whether the S15 false-positive amplification generalizes: rule-context vs no-rule-context, five runs per condition, run on every hard-benign and every decoy-family holdout scenario.

In contrast to rule-only correlation (rule-matched events, no cross-window synthesis) and unconstrained LLM analysis (free-form generation, weak grounding), the pipeline requires structured-event citations and validates them mechanically; partially constrained systems exist [13], [14] and are compared in Section III.

Stated sharply, the novelty is methodological, and threefold: to our knowledge this is the first controlled comparison of deterministic rules and an LLM *over the same normalized forensic event schema* in which (i) every LLM claim is bound to event-identifier citations checked by a deterministic validator, (ii) verdict accuracy, suspect attribution, and citation grounding are scored as three separate correctness axes, and (iii) adversarial failure cases are designed into the corpus and retained — yielding the two boundary results (grounded-but-misattributed S14; ablation-confirmed rule-context contamination S15) that no prior LLM-forensics evaluation reports. Table I contrasts our

approach with the two paradigms it sits between; Section III compares against specific prior systems.

II. BACKGROUND

Terminology. A *private cloud* is self-managed infrastructure operated by one organization. *Triage*, unlike real-time detection, operates on already-collected logs after an incident trigger and produces output a human reviews before action [4]; the base-rate and deployment-gap critiques of machine learning for intrusion detection [15], [16] apply in full. *Evidence grounding* here means every reported claim cites normalized event identifiers that exist in the scenario evidence; it does *not* mean the interpretation drawn from those events is correct. *Citation validation* is the deterministic post-hoc check of that property. The distinction between *citation grounding* (cited events exist) and *interpretive grounding* (cited events support the conclusion) is strictly meaningful — the latter is stronger [17] — and the evaluation is organized around the gap.

Cloud forensics. NIST catalogues sixty-five cloud forensic challenges, many reducing to evidence fragmentation [2]; surveys [3] and acquisition tooling such as FROST [18] establish the problem this paper starts from, and super-timeline practice [19] is the manual ancestor of the automated timeline layer. This thread provides no reasoning layer.

III. RELATED WORK (SURVEY)

We survey five threads. Each is summarized against this paper’s question in Table II.

Rule-based monitoring and log analytics. Alert fatigue is structural: rules tuned against false negatives exceed analyst capacity [5], and ML-based alert suppression addresses volume, not reasoning [6]. Provenance systems correlate causally but need kernel-level audit data [20], [21]. Sequence models (DeepLog [22]) and prompted LLMs (LogGPT [23]) detect anomalous log sequences but produce no evidence-cited investigative narrative and measure no hallucination.

LLMs for security operations. Surveys map LLM use across security operations center (SOC) functions [8]; a ten-month study of forty-five analysts found LLMs used for sensemaking, not high-stakes determinations [24] — central to the deployment posture argued here. Multi-agent triage [25] and retrieval-grounded incident analysis [26], [27] target streaming workflows; none enforce per-claim event-ID citation over a forensic schema. Relatedly, LLM-integrated applications inherit manipulation risk from their input context via prompt injection [28]; the S14/S15 effects measured here are data-level instances of context-steered conclusions.

LLMs for digital forensics (DFIR). Scanlon et al. concluded unconstrained LLM use in evidence-bearing workflows is premature [11]; later surveys identify non-determinism and hallucination as the core integrity challenges [9], [29]. Studiawan et al. show the same model swings from BLEU 0.15 to 0.95 with prompt structure [30], so capability claims are often prompting claims — partially mitigated here by one fixed published prompt. GenDFIR pairs rule-based artifact

TABLE I
OUR WORK VERSUS THE TWO PARADIGMS IT SITS BETWEEN. PER-SYSTEM COMPARISON AGAINST RELATED WORK APPEARS IN TABLE II.

Axis	Rule-based SIEM correlation	Unconstrained LLM analysis	Evidence-grounded LLM triage (this work)
Reasoning input	Structured normalized events	Raw or structured logs	Structured normalized events + rule-alert context
Reasoning model	Fixed threshold predicates	Free-form generation	Constrained reasoning over cited events
Evidence grounding	Rule-matched events only	Often weak or absent	Event-ID citation required for every claim
Hallucination control	Not applicable	Prompt-only or absent	Deterministic seven-check validator (99.95% citation validity)
Cross-day attack patterns	Limited (local triggers)	Plausible but unmeasured	100% recall, measured (S4, S13, CERT)
Benign-noise handling	High alert volume	Unmeasured	Measured weakness (benign FP), reported
Failure modes	Partially reported	Usually hidden	S14, S15 designed-in and analyzed
Deployment	Established on-prem	Often closed-API	Open-weight, in-boundary capable

selection with retrieval-augmented Llama reasoning over incident timelines [13] and is the closest system, but does not separate verdict from suspect attribution and grounding, nor characterize failure modes; DFIR-Metric contributes a broad benchmark [31]; ForensicLLM targets local deployment under the same data-sovereignty constraint [32]; cloud-specific LLM forensics classifies audit logs and reconstructs timelines [33], and OMNISEC retrieves behavioral context for provenance-based detection [14]. None publish controlled rule-vs-LLM comparisons with deterministic citation validation and retained failure cases.

Evidence-grounded generation. Hallucination cannot be fully eliminated [10], [34], motivating validation over trust. Retrieval-augmented generation supplies external evidence [35]; attribution work evaluates whether output is supported by cited sources [36], [37]; constrained decoding enforces machine-readable output [38]; self-consistency improves reliability [39], though stated reasoning is not always faithful to what drives the answer [40]. Citation correctness being necessary but insufficient for reliability [17] is exactly what S14 instantiates in the forensic domain. Open-weight families [12], [41], [42] make on-premises deployment satisfiable.

Insider threat. Synthetic ground-truth benchmarking is established (CERT [1]); multi-day behavioral patterns are learnable [43]; public datasets (LANL [44], DARPA OpTC [45]) anchor future real-data validation. OrgForge-IT couples verifiable synthetic ground truth with LLM evaluation [46] but does not separate verdict from suspect-attribution failures.

Table II summarizes the gap: no prior work evaluates deterministic rules and evidence-grounded LLM reasoning side by side over the same normalized forensic schema with verdict, suspect, and grounding scored separately and failure cases retained.

IV. PROBLEM STATEMENT AND THREAT MODEL

After an incident trigger, an investigator receives collected logs from seven surfaces (authentication, file access, admin, network, database, web server, email) for a bounded window and

must answer: (Q1) did an incident occur (ATTACK/BENIGN)? (Q2) who is the primary suspect and what was the step sequence? (Q3) what evidence supports each claim, verifiably against stored logs?

The adversary is an external attacker with compromised credentials or a malicious insider with legitimate ones. It can generate log events on any surface, spread activity across days to stay under thresholds, blend into maintenance or business peaks, and stage *decoy* activity by one identity to misdirect attention from a quieter attack by another. It cannot tamper with stored logs after collection (integrity assumed per forensic practice [4]; deletion *attempts* appear as logged `log_delete` events) and cannot influence the analysis pipeline. The defender’s components — rules, LLM, validator — are trusted but fallible; the LLM is treated as a potentially unreliable component whose output must be validated. Forensic data must not leave the organizational boundary, excluding closed third-party LLM APIs and motivating open-weight, locally servable models [12], [32].

The task: produce a triage output — verdict, suspect, ordered attack chain, supporting/counter evidence, gaps — maximizing verdict accuracy against ground truth while every claim cites event identifiers present in the evidence, with violations mechanically detectable. The comparison object is a transparent rule baseline over the same evidence.

V. SYSTEM DESIGN AND IMPLEMENTATION

Three principles drive the design. *Equal evidence access*: both analyzers consume the same correlated normalized timeline, so accuracy differences are attributable to reasoning, not privileged input. *Claims bound to evidence*: the LLM may only reason over events in its input and must cite event identifiers; a deterministic validator checks this afterward. *Failure transparency*: scenarios the LLM fails are retained and analyzed. Fig. 1 shows the pipeline.

TABLE II
POSITIONING OF THIS PAPER AGAINST RELATED WORK THREADS.

Work area	Typical approach	Limitation for this paper's question	How this paper differs
Cloud forensics [2], [3], [18]	Challenge catalogues, acquisition tools, standards	No automated reasoning layer	Constrained reasoning layer over normalized evidence
SIEM rules / log analytics [5], [6], [22], [23]	Threshold correlation; sequence anomaly models	No cited investigative narrative; hallucination unmeasured	Rules as transparent baseline <i>and</i> LLM input, contamination measured (S15)
LLMs for SOC [8], [24]–[26]	Streaming alert triage, agents, retrieval enrichment	No per-claim event-ID enforcement	Deterministic citation validator; failure cases preserved
LLMs for DFIR [11], [13], [14], [30], [31], [33]	Timeline analysis, benchmarks, cloud variants	Verdict/suspect/grounding failures conflated	Three correctness axes scored separately
Evidence grounding [17], [35]–[37]	Document retrieval with cited sources	Citation $\neq$ interpretive correctness; free-text framing	Structured-event citation; S14 shows grounded-but-wrong attribution
Insider threat [1], [43], [46]	Behavioral anomaly detection; LLM benchmarks	Suspect attribution rarely separated	S4/S13 target multi-day patterns rules miss; suspect scored separately

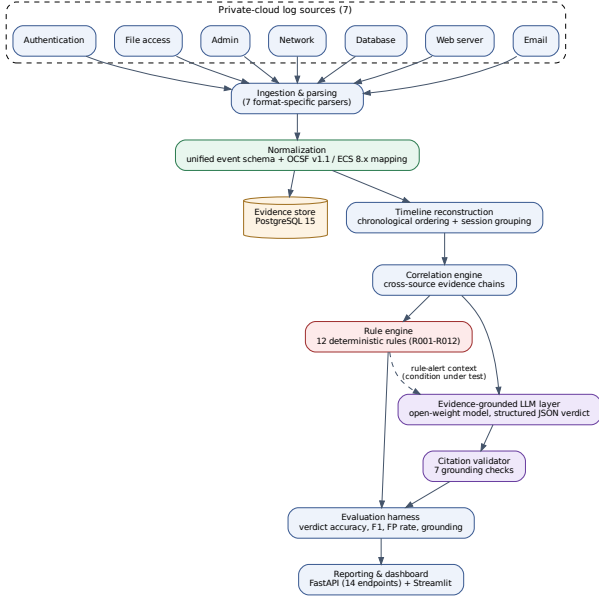


Fig. 1. System architecture. Both analyzers consume the same correlated timeline; the dashed edge marks the rule-context input whose effect is isolated in the S15 ablation.

A. Normalization, Timeline, and Correlation

Seven source types — authentication (login/logout/failures with IPs), file access (reads/downloads with paths and sizes), admin (privilege changes, log deletion), network (DNS, firewall, VPN), database (queries, exports), web server (requests, errors), and email — are parsed from source-specific formats onto a unified record: `event_id`, timezone-aware `timestamp`, `source_type`, `user`, `action`, `resource`, `source_ip`, `status`, `session_id`, `severity`, and `metadata` (tickets, justifications). Ground truth lives in a separate file, and underscore-prefixed metadata is stripped at normalization to

prevent leakage of evaluation hints into either analyzer. Events also map to Open Cybersecurity Schema Framework (OCSF) v1.1 [47] and Elastic Common Schema (ECS) 8.x for SIEM interoperability, though experiments use the unified schema. Normalized events are sorted chronologically and grouped by session (surfacing mid-session IP changes), by user (supporting rolling-window aggregation), and by cross-source linking (same user within a proximity window), with no heuristic attack-step labeling — both analyzers see the same lightly grouped event list.

B. Rule Engine

Twelve rules (Table III), declared in YAML and evaluated against the stream and per-user behavioral baselines (normal IPs, hours, directories for four personas), emit alerts citing rule, events, and severity. A fixed mapping derives the scenario verdict: any critical alert $\rightarrow$ `attack`; warnings only $\rightarrow$ `suspicious`; none $\rightarrow$ `no_alert`. The baseline is deliberately a transparent threshold-style configuration — auditable by operators — not a tuned SIEM policy, and the comparison must be read accordingly.

C. LLM Reasoning Layer and Validator

The LLM never sees raw logs. In the headline **rule-context condition** it receives per-user baselines, the correlated timeline, and the rule alerts; a diagnostic **no-rule-context condition** omits the alerts (Section VII-F). It must return fixed JSON [38]: `verdict` (YES/NO/INSUFFICIENT), `suspect`, an ordered attack chain whose every step cites an `event_id`, supporting/counter-evidence citation lists, gaps, and confidence. The system prompt enforces: only listed events may be reasoned over; no event may be assumed or invented; insufficiency must be reported; every claim must cite input `event_ids`. Guidance disambiguates rule-hostile cases (failed logins without success are not breaches; maintenance can legitimately include privilege changes and bulk operations; tickets can be fabricated and

TABLE III
THE TWELVE RULES IN THE RULE BASELINE.

ID	Name	Severity	Trigger (informal)
R001	unusual_login_ip	warning	login from IP outside baseline
R002	off_hours_access	warning	activity outside normal hours
R003	privilege_escalation	critical	any privilege_change
R004	bulk_download	critical	> 5 downloads in 30 min
R005	cross_department_access	warning	resource outside user's directories
R006	log_deletion	critical	any log_delete
R007	failed_login_spike	warning	≥ 2 failures in 5 min
R008	privilege_then_download	critical	R003 then download in 30 min
R009	dns_tunnel_detection	critical	> 20 queries, one domain, 5 min
R010	sql_injection_attempt	critical	HTTP 500 + SQL keywords in URL
R011	data_exfiltration_volume	critical	outbound > 100 MB in 30 min
R012	lateral_movement	warning	auth on ≥ 3 server types, 30 min

multi-day read-then-download scope creep stays suspicious; a mid-session IP change is a hijack indicator).

The model is an open-weight Gemma instruction model [12] at temperature 0.1 behind an OpenAI-compatible endpoint — in this evaluation a third-party Modal serverless endpoint, acceptable because all data is synthetic; substituting in-boundary vLLM/Ollama/TGI serving is a configuration change, so data sovereignty is an *architectural* property validated by interface compatibility, not exercised here.

Every output passes a deterministic validator with seven checks: cited event-ID existence; chronological ordering of the cited chain; structural unsupported-claim count (steps/narrative without `evt_*` references); actor consistency (every named user exists in the input); temporal-claim consistency; volume-claim consistency; and entity consistency (IPs/files in the narrative appear in cited events). Fig. 2 shows an actual grounded response and the checks applied to it. The validator enforces only that claims are tied to evidence present in the input; it does not detect causal overclaim, missing alternative explanations, or a wrong suspect supported by real events — gaps S14 makes concrete.

D. Scenario Corpus and Implementation

The corpus has two parts: the 15-scenario **calibration set** (Table IV; primary tier S1–S4 and extended robustness tier S5–S15 including two adversarial failure probes, S14 and S15), on which the LLM system prompt was iteratively tuned; and the 100-scenario **holdout set** (S16–S115) produced by a parameter-driven generator (`app/ingestion/scenario_factory.py`) under seed 42 from a committed YAML spec (`config/corpus_spec.yaml`). The holdout is balanced across ten families: `normal_baseline` (10 benign), `travel_noise` (10 benign), `credential_compromise` (12 attack), `scope_creep` (12 attack), `session_hijack`

Grounded LLM output—S4 (slow insider), actual response

```
"verdict": "YES", "suspect": "user_03",
"attack_chain": [
  { "step": 1, "event_id": "evt_s4_002",
    "description": "User_03 obtains read
    access to finance reports, ticket
    HR-2026-441...", "confidence": "HIGH" },
  { "step": 2, "event_id": "evt_s4_004", ... },
  ... ]
"evidence_for": [ "evt_s4_002", "evt_s4_010",
  "evt_s4_012", "evt_s4_014", "evt_s4_019",
  ... ]
```

Deterministic validator pass over this response

event-ID existence: all cited <code>evt_s4_*</code> resolve	PASS
actor consistency: <code>user_03</code> present in evidence	PASS
entity consistency: cited paths / IPs present	PASS
chronology: one chain step out of timestamp order	FLAGGED

Fig. 2. Evidence-grounded output and deterministic validation (real S4 artifacts). Every claim carries an **event_id** (teal); the validator resolves each citation against the stored evidence and flags violations — here, S4's single chronology violation.

TABLE IV
SCENARIO CORPUS (GT = GROUND TRUTH).

ID	Scenario	GT
S1	Normal weekday baseline	BENIGN
S2	Noisy benign: conference travel	BENIGN
S3	Obvious external attack	ATTACK
S4	Slow three-day insider scope creep	ATTACK
S5	Session hijack, mid-session IP change	ATTACK
S6	After-hours sanctioned maintenance	BENIGN
S7	Failed credential stuffing (no breach)	BENIGN
S8	Full-infrastructure attack (SQLi, DB export, DNS tunnel)	ATTACK
S9	Attack with missing auth logs	ATTACK
S10	Attack with delayed, out-of-order events	ATTACK
S11	Benign day, then account compromise	ATTACK
S12	Conflicting signals	ATTACK
S13	Ultra-slow exfiltration over seven days	ATTACK
S14	Decoy misdirection (loud decoy, quiet attacker)	ATTACK
S15	End-of-quarter legitimate bulk activity	BENIGN

(10 attack), `maintenance_window` (8 benign), `failed_stuffing` (8 benign), `multistage_infra` (12 attack), `decoy_misdirection` (10 attack), `legitimate_peak` (8 benign). Of the 44 benign scenarios in the holdout, 34 are *hard benign* — benign labels designed to generate alert load. Personas are extended from the four hand-written calibration personas to ten (`user_05`–`user_10` are generator-created from declared role/department parameters).

The engine is ~5k lines of Python 3.11 (ingestion, normalization, timeline, correlation, rules, LLM client, validator, evaluation, reporting), with a FastAPI service (14 endpoints), a Streamlit dashboard, PostgreSQL 15 persistence (`events`, `alerts`, `llm_results`, `evaluation_results`), and a

Laravel orchestration layer writing an append-only audit trail; deployment is a two-container Docker Compose stack. A 59-case pytest suite covers parsers, normalization, rules, validator, API, and the scenario generator (schema validity, label balance, determinism, no-leakage); six driver scripts reproduce the pipeline, evaluation, stress tests, the calibration-set ablation, the extended hard-benign / decoy ablation, and the corpus-wide run-to-run variance probe. The corpus generator is parameter-driven from `config/corpus_spec.yaml` under a fixed seed.¹

VI. MATHEMATICAL MODEL

Let $\mathcal{S} = \mathcal{S}_{\text{cal}} \cup \mathcal{S}_{\text{hold}}$ with $|\mathcal{S}_{\text{cal}}|=15$ author-designed calibration scenarios and $|\mathcal{S}_{\text{hold}}|=100$ generator-created holdout scenarios sampled deterministically from the committed family distribution in `config/corpus_spec.yaml` under seed 42. Every s_i carries a ground-truth label $y_i \in \{\text{BENIGN}, \text{ATTACK}\}$ fixed a priori; Σ is the set of seven source types. Source-specific normalizers ν_σ yield the evidence set

$$E_i = \bigcup_{\sigma \in \Sigma} \nu_\sigma(L_{i,\sigma}), \quad e = (id, t, u, \sigma, a, r, ip, sess, v, m), \quad (1)$$

with identifier, timestamp, actor, source, action, resource, IP, session, volume, and metadata; $\text{ids}(E_i)$ denotes the identifier set. The timeline operator τ sorts E_i into $\mathcal{T}_i = \langle e_{(1)}, \dots, e_{(n_i)} \rangle$ with non-decreasing t ; the correlator partitions $\mathcal{T}_i$ by session and links cross-source events of one actor within proximity δ (30 min).

Each rule ρ_k , $k \leq 12$, is a pair (P_k, w_k) of a deterministic predicate over event subsets and a severity $w_k \in \{\text{WARNING}, \text{CRITICAL}\}$; the alert set is

$$A_i = \{(k, G) : G \subseteq E_i, P_k(G)\}, \quad (2)$$

and the rule verdict is `attack` if any critical alert exists, `suspicious` if only warnings, else `no_alert`. A full rule pass is approximately $O(K|E_i| + |E_i| \log |E_i|)$.

The LLM with parameters θ is a stochastic map

$$\Lambda_\theta : (B, \mathcal{T}_i, A_i) \mapsto r_i = (v_i, u_i^*, C_i, F_i, \bar{F}_i, g_i), \quad (3)$$

over baselines B , timeline, and (in the rule-context condition) alerts, returning verdict $v_i \in \{\text{YES}, \text{NO}, \text{INSUFFICIENT}\}$, suspect u_i^* , chain $C_i = \langle c_1, \dots, c_{m_i} \rangle$ with citation sets $\text{cite}(c_j)$, and evidence lists $F_i, \bar{F}_i$ of *claimed* identifier strings (not guaranteed to lie in $\text{ids}(E_i)$ — validation checks exactly that). The no-rule-context condition is $\Lambda_\theta(B, \mathcal{T}_i, \emptyset)$. One projection μ on the union of verdict alphabets maps `attack/YES` to `ATTACK` and all else to `BENIGN`; mapping `INSUFFICIENT` to `BENIGN` scores abstention on an attack as *incorrect*, since a verdict that asserts nothing has no triage value.

¹Scenario corpus, rules, prompts, validator, generator, statistics module, real-data adapters (LANL, OpTC), and all per-scenario result artifacts are available from the author as a reproducibility package.

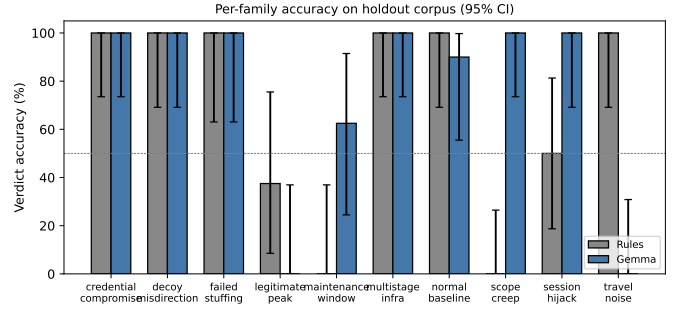


Fig. 3. Per-family accuracy on the 115-scenario corpus, rules vs Gemma, with exact 95% Clopper-Pearson intervals.

With $\text{cite}(r_i) = \bigcup_j \text{cite}(c_j) \cup F_i \cup \bar{F}_i$, step timestamps $t(c_j) = \min\{t(e) : id(e) \in \text{cite}(c_j)\}$, and $\mathcal{U}(r_i)$ the users named in r_i , the validator computes

$$\chi_{\text{exist}}(r_i) = |\text{cite}(r_i) \setminus \text{ids}(E_i)|, \quad (4)$$

$$\chi_{\text{chron}}(r_i) = |\{1 \leq j < m_i : t(c_j) > t(c_{j+1})\}|, \quad (5)$$

$$\chi_{\text{actor}}(r_i) = |\mathcal{U}(r_i) \setminus \{u(e) : e \in E_i\}|, \quad (6)$$

plus entity, temporal, volume, and structural counts defined analogously. A response is *citation-grounded* iff $\chi_{\text{exist}}(r_i) = 0$; the corpus citation validity rate is

$$\gamma = 1 - \frac{\sum_i \chi_{\text{exist}}(r_i)}{\sum_i |\text{cite}(r_i)|} = 1 - \frac{1}{2068} = 0.99952, \quad (7)$$

reported as 99.95% across all 115 scenarios (calibration 226/226 = 100%; holdout 1841/1842 = 99.95%; the single invalid reference is on a holdout scenario). Crucially, $\chi_{\text{exist}}(r_i) = 0$ does not imply u_i^* is the true attacker: citation grounding is necessary, not sufficient, for interpretive correctness (S14).

Verdict accuracy is $\text{Acc}(X) = \frac{1}{|\mathcal{S}|} \sum_i \mathbf{1}[\mu(V_X(s_i)) = y_i]$. Step precision/recall/ F_1 match reported chain steps (rule alerts, for rules) against labeled ground-truth steps *independently of verdict correctness*, and are sensitive to step-label naming (Section VIII). The alert load on a benign scenario, $\phi_i = |A_i|/|E_i| \times 100\%$, counts alert instances over events and may exceed 100% (observed: $\phi_{S6} = 132\%$).

VII. EVALUATION

All 115 scenarios run through the full pipeline; both analyzers consume the same timeline, the LLM additionally receiving rule alerts (rule-context condition). Three metric families are kept separate — verdict accuracy, suspect/attack-chain correctness, grounding integrity — because the two key findings (S14, S15) fail on different axes and would vanish in a single score. Headline results are reported on the holdout split ($n=100$); calibration results ($n=15$) are reported in parallel because the LLM prompt was tuned on those scenarios. All figures are computed by the evaluation harness from persisted artifacts (`data/evaluation_results.json`, `data/statistics_report.json`).

TABLE V
HEADLINE ACCURACY ACROSS THE 100-SCENARIO HOLDOUT (95% CLOPPER-PEARSON CI), WITH CALIBRATION ($n=15$) AND FULL CORPUS ($n=115$) IN PARALLEL. BRACKETED VALUES ARE 95% CONFIDENCE INTERVALS; p IS THE PAIRED McNEMAR EXACT TEST (RULES VS. GEMMA).

Slice	N	Rules % [95% CI]	Gemma % [95% CI]	McNemar p
Calibration ($n=15$, prompt-tuned)	15	66.7 [38.4, 88.2]	86.7 [59.5, 98.3]	0.453
Holdout (generator-created)	100	70.0 [60.0, 78.8]	78.0 [68.6, 85.7]	0.243
Full corpus	115	69.6 [60.3, 77.8]	79.1 [70.6, 86.1]	0.126
Holdout — attack only	56	69.6 [55.9, 81.2]	100.0 [93.6, 100.0]	< 0.001
Holdout — benign only	44	70.5 [54.8, 83.2]	50.0 [34.6, 65.4]	0.064
Holdout — hard benign	34	61.8 [43.6, 77.8]	38.2 [22.2, 56.4]	0.096

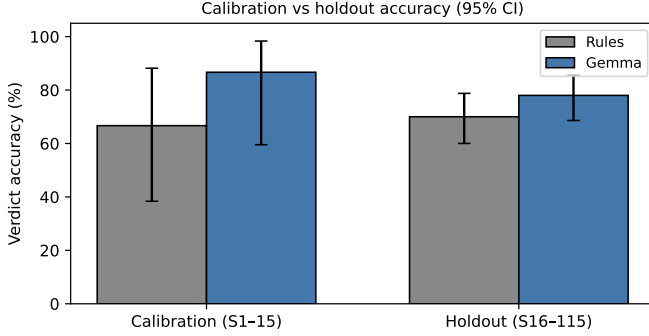


Fig. 4. Calibration ($n=15$, prompt-tuned) vs holdout ($n=100$, generator-created). The LLM advantage shrinks substantially on the holdout split.

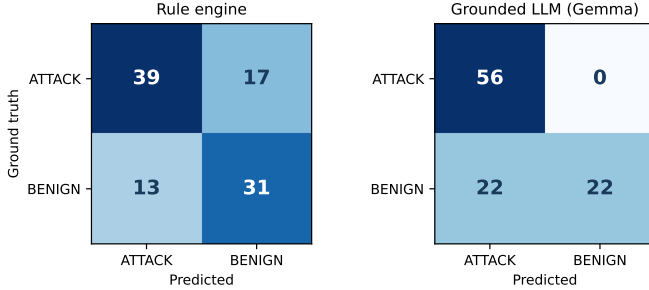


Fig. 5. Holdout confusion matrices ($n=100$). The LLM misses no attack (top-right cell 0) but misclassifies 22 of 44 benign scenarios as attacks; the rule engine errs in both directions.

A. Verdict Accuracy and False Positives

Table V and Figs. 3–4 summarize the headline. On the calibration set the LLM advantage that motivated the prompt design (86.7% vs 66.7%) is wide but underpowered ($n=15$); on the 100-scenario holdout the gap narrows to 78.0% vs 70.0% — a paired improvement of +8.0 percentage points whose bootstrap 95% interval (10 000 resamples) of $[-4.0, +20.0]$ crosses zero, and whose McNemar exact test is not significant ($p=0.243$).

Statistical treatment. Fig. 5 shows the holdout confusion matrices. On the holdout the two systems are *not* statistically distinguishable on overall accuracy. They are sharply different by label. On attack scenarios Gemma reaches 100.0% [93.6, 100.0] versus 69.6% for rules, a +30.4 pp improvement with bootstrap 95% CI $[+17.9, +42.9]$ and McNemar $p<0.001$. On

benign scenarios the direction reverses: Gemma 50.0% [34.6, 65.4] versus rules 70.5% [54.8, 83.2] (−20.5 pp, $p=0.064$). On the 34 hard-benign scenarios (benign labels intentionally designed to fire alerts), Gemma falls to 38.2% versus 61.8% for rules. The LLM, as deployed, is best characterised as a high-recall attack detector with a substantial false-positive rate on legitimate-but-noisy activity.

Per-family decomposition. The label-dependent skew has a structural explanation. Gemma reaches 100% on five attack-heavy families (credential_compromise, decoy_misdirection, failed_stuffing, multistage_infra, scope_creep) and on session_hijack, where the rule engine reaches only 50% (it sees the IP change as a single warning, not an incident). On scope_creep the rule engine scores 0% — no rule aggregates cross-department reads over multiple days — and Gemma 100%. The compensating losses fall on travel_noise (rules 100%, Gemma 0%) and legitimate_peak (rules 37.5%, Gemma 0%): both are high-volume benign families where the LLM consistently misreads workload spikes from foreign IPs or end-of-quarter activity as attack. The maintenance_window family inverts in Gemma’s favour (rules 0%, Gemma 62.5%); rules fire on the privilege-then-log-delete pattern regardless of ticket context, whereas the LLM partially reads the ticket and role.

B. Subtle and Degraded-Evidence Attacks

The calibration findings extend to the holdout. On S4 (three-day insider scope creep) both verdicts are correct, but rule alerts capture only the privilege event and cross-department reads (step $F_1=0.10$) while the LLM names the multi-day read-then-download progression ($F_1=0.91$); the holdout scope_creep family generalises this pattern (12 attack scenarios with 1–4 cross-department files per day over 3–10 days): rules 0/12, Gemma 12/12. On S5 rules yield only warnings (verdict-wrong, though their alerts overlap labeled steps — step scores are verdict-independent), while the LLM flags the mid-session IP change ($F_1=0.92$); on the holdout session_hijack family (10 scenarios) the same pattern holds, rules 5/10, Gemma 10/10. On S10, S12, and S13 (low-and-slow exfiltration [7]) rule verdicts map BENIGN; the LLM is correct, aggregating across days on S13. The remaining attacks (S8, S11, S9) are verdict-correct for both; on S9 the LLM also lists the missing authentication evidence in its gaps field — the desired behavior under incomplete evidence.

C. Grounding Results

Of 2068 event-identifier references across the 115-scenario corpus, 2067 resolve to real events ($\gamma = 99.95\%$, exact 95% CI [99.73, 99.999]); 114 of 115 scenarios have zero invalid citations. The single invalid reference is a natural-language sentence (“*user_02’s travel_note indicates they frequently travel...*”) placed in an `evidence_for` list where an event identifier was required — a structural formatting failure, not a fabricated event identifier. **No fabricated event identifier was observed across the entire corpus.** Only one chronology violation was observed across all 115 scenarios (a single out-of-order step on a holdout travel scenario whose chain interleaves login and file-access events near a session-start cluster). Actor and entity checks: no violations on the holdout. Volume and temporal checks were never triggered, so their behavior is unmeasured at scale. The grounding claim is therefore bounded: *no fabricated event identifiers, 99.95% citation validity, and at most one chronology violation across 115 scenarios under the implemented validator* — not “hallucination-free” [34], but materially stronger than the 99.2% reported on the calibration corpus alone.

D. Third-Party Benchmark Replay (CERT r4.2)

The synthetic results above were both generated by the authors — the calibration scenarios hand-authored, the holdout produced by an author-written generator. To probe ecological validity we replay the pipeline on the CERT Insider Threat Test Dataset r4.2 [1], an independently constructed corpus distributed by CMU CERT. We map five r4.2 streams (`logon`, `device`, `file`, `email`, `http`) onto the unified event schema via `app/ingestion/adapters/cert_insider.py`; the field mapping is documented in the module docstring. Investigation units are per-user-month windows: each labeled insider in r4.2 contributes one ATTACK window per active calendar month; BENIGN windows are sampled from users absent from `answers/insiders.csv`, with the seeded RNG rejecting samples whose median event count differs from the ATTACK median by more than 25% (final median diff 9.8%). Windows are capped at 150 events to fit Gemma’s 32K context; admin/device/file events are kept fully and `logon/http/email` are uniformly thinned per day, with the downsampling flag recorded in `data/real_scenarios/manifest.json`.

We attempted 40 windows (20 ATTACK + 20 BENIGN). Five BENIGN windows did not complete because the Modal endpoint stalled mid-run for an extended period in two separate outages; we report scored results on the 35 windows that completed cleanly (20 ATTACK + 15 BENIGN) and document the outage explicitly rather than approximate the missing five.

Format drift on real-world inputs (a finding in itself). On the richer CERT prompts, Gemma abandoned the requested JSON schema and returned free-form Markdown forensic reports in 34 of the 35 scored windows; only one window produced schema-valid JSON. For the 34 Markdown responses a deterministic parser extracted the binary verdict from the report’s conclusion (these records are tagged `source: live_narrative_coerced` in

`data/llm_responses/cert/`), and all 35 are genuine model calls (no mock outputs; per-call latency 14.8–31.7 s). Two consequences follow and we state them plainly. First, the structured citation validator could be applied to only the single JSON response (20 references — 14 supporting events plus 6 attack-chain steps — all of which resolved to real events); the Markdown responses cite schema-correct identifiers such as `cert_http_*` inline but these were not systematically validated, so the strong grounding result of the synthetic corpus (Section VII-C) is *not* re-established at scale on CERT. Second, prose-to-verdict extraction is imperfect: manual review of the 15 benign reports finds 13 whose own text concludes “insider threat” and 2 (BEH0615, MAD0753) whose text leans benign but were coerced to YES, so the benign accuracy is more honestly read as near-zero (at most 2/15 correct) than as an exact 0%. That this format drift appears only on the more verbose real-world inputs is itself a deployment-relevant robustness limitation of schema-constrained LLM triage.

The synthetic-corpus rule baseline is uncalibrated for CERT (the twelve rules were tuned for a different schema vocabulary: `usb_connect` and `file_copy` actions never appear in the synthetic corpus and never trigger R001–R012), so the 42.9% rule accuracy is a no-baseline figure that mostly reflects benigns mapping to BENIGN; the McNemar test is therefore not the right summary. The relevant pre-registered comparisons are:

(Q1) Does the attack-recall / benign-FP asymmetry from the synthetic holdout replicate on third-party data? Yes, and it intensifies. Synthetic holdout: 100% attack accuracy vs 50% benign accuracy (a 50 pp gap). CERT r4.2: 100% attack vs near-zero benign accuracy (at most 2 of 15 benign windows arguably correct; a ≥ 87 pp gap). The LLM flags almost every benign user-month as an incident.

(Q2) Does the multi-day insider recall that drove the synthetic S4 and S13 results hold on CERT’s real insider cases? Yes. All 20 CERT attack windows — across r4.2 insider scenarios 1, 2, and 3 — received YES (the verdict, where coerced, taken from the report’s explicit conclusion), including the scenario 2 cases that involve job-hunting and gradual scope expansion exactly analogous to S4 in the calibration set. Where structured citations were available (the single JSON response), all 20 resolved to real events with no chronology violation; as noted above, structured grounding could not be assessed on the 34 Markdown responses.

The forensic interpretation is unchanged from the synthetic conclusion and reinforced by the third-party replay: grounded LLM triage is a high-recall, low-precision first-pass layer. CERT shows that the recall property is robust enough to survive a corpus the authors never touched, and that the precision deficit on legitimate-but-noisy activity is not a synthetic artefact: when the LLM has no explicit baseline saying “this user is allowed to email attachments”, it treats USB use, late-night logins, and unusual web browsing as evidence of insider activity.

E. Stress Tests

Four dimensions probe robustness (Fig. 6); coverage varies (raw-log comparison: S3–S5; removal and noise: S3–S4; jitter:

TABLE VI

CERT R4.2 REPLAY: 35 OF 40 WINDOWS SCORED (5 LOST TO ENDPOINT OUTAGE). VERDICTS FOR 34 OF 35 WINDOWS WERE EXTRACTED FROM MARKDOWN REPORTS (THE MODEL ABANDONED THE JSON SCHEMA; SEE TEXT); BENIGN ACCURACY IS THE COERCED-VERDICT FIGURE AND IS NEAR-ZERO (AT MOST 2/15 BORDERLINE). BRACKETED VALUES ARE 95% CLOPPER–PEARSON CONFIDENCE INTERVALS.

Slice	N	Rules % [95% CI]	Gemma % [95% CI]
All CERT scenarios scored	35	42.9 [26.3, 60.6]	57.1 [39.4, 73.7]
CERT attacks only	20	0.0	100.0 [83.2, 100.0]
CERT benigns only	15	100.0	0.0 [0.0, 21.8]
Insider scenario 1	5	0.0	100.0
Insider scenario 2	12	0.0	100.0
Insider scenario 3	3	0.0	100.0

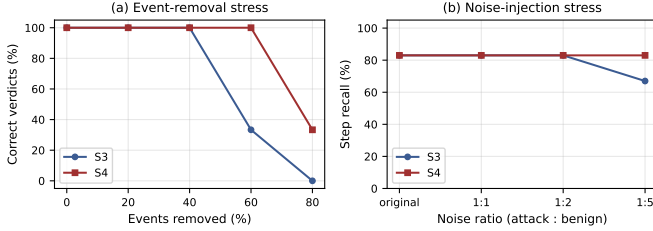


Fig. 6. Stress tests: (a) verdict correctness under random evidence removal (3 trials/level); (b) step recall under benign-noise injection.

S3), and trial counts are small ($N=3$ per level), so results are observations, not powered estimates. **(A) Raw logs vs. pipeline:** on raw unnormalized logs the LLM still reaches correct verdicts but emits hallucination-flagged claims on two of three scenarios; the full pipeline yields zero on all three — structuring removes grounding violations. **(B) Evidence removal:** at 20–40% removal, 12/12 trials correct; S3 degrades to INSUFFICIENT at 60–80%, S4 only at 80%. The starvation failure mode is *abstention*, not fabrication: four hallucination flags across 24 perturbed trials, and no fabricated event identifier. **(C) Noise injection:** verdicts correct at all noise ratios up to 5:1; S3 step recall drops 83%→67% only at 5:1; S4 stable at 83%. **(D) Timestamp jitter** (5 min–2 h): verdicts stay correct and chain ordering internally consistent, while the validator’s strict timeline check flags jittered chronology — intended auditor behavior under perturbed clocks.

F. Failure Cases

S14 — decoy misdirection (suspect failure, validator-silent). A loud decoy compromise of `user_04` (brute force, privilege escalation, bulk downloads; 21 alerts) runs concurrently with the real attack: quiet lateral movement and DNS-tunnel source-code exfiltration by `user_02` (Fig. 7). The LLM returns YES — verdict *correct* — but names `user_04` as suspect and builds its chain from the decoy’s events. Every cited event is real and ordered; no validator check fires. Citation grounding held; interpretive grounding failed. An adversary who stages plausible events can satisfy every citation check while misdirecting the analyzer.

S15 — rule-context amplification (verdict failure, ablation-confirmed on the calibration set). Legitimate quarter-end activity yields ten alerts that the rule mapping correctly

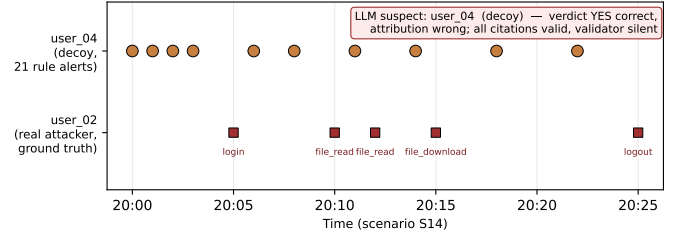


Fig. 7. S14 attribution failure, plotted from the actual scenario events. The decoy (`user_04`, circles) generates loud, alert-heavy activity; the real attacker (`user_02`, squares) operates quietly in parallel. The LLM cites only real events — and attributes the incident to the decoy.

absorbs to BENIGN; the LLM in the rule-context condition returns YES. Re-running S15 five times per condition on the same model and timeline: with rule context, YES 5/5; without, NO 5/5 (Table VIII). On S15 alone the verdict reverses unanimously on the rule-alert artifact.

Hard-benign false positives (generalised failure mode). The holdout corpus contains 34 hard-benign scenarios (benign labels designed to produce alert load, drawn from `travel_noise`, `maintenance_window`, `failed_stuffing`, and `legitimate_peak` families). On these the LLM scores only 38.2%, against 61.8% for the rule engine. An extended ablation — rule-context vs no-rule-context, five runs per condition — was run on all 44 hard-benign and decoy holdout scenarios (440 calls). Of those 44 scenarios, the verdict reversed between conditions for only 6 (Table VII): three `travel_noise` (s27, s28, s32) and three `maintenance-window` (s71, s73, s75). On the other 38 scenarios the verdict was identical in both conditions — including all eight `legitimate_peak` scenarios, on which the LLM returned YES with and without rule alerts in the prompt. The S15 rule-context amplification effect therefore generalises only partially: it is a real but minority mechanism. The LLM’s over-classification of legitimate-but-noisy patterns (foreign-IP travel sessions, end-of-quarter file volumes) is dominated by a model-intrinsic prior, not by upstream alert injection.

Manual inspection also finds occasional intent assertions logs cannot support (causal overclaim) and missing benign counter-hypotheses (on S15, no explicit “quarterly close” alternative; on holdout travel scenarios, no explicit “business

TABLE VII

EXTENDED RULE-CONTEXT ABLATION: 44 HARD-BENIGN AND DECOY HOLDOUT SCENARIOS, FIVE RUNS PER CONDITION (440 CALLS TOTAL).

REVERSALS ARE SCENARIOS WHERE RULE-CONTEXT AND NO-RULE-CONTEXT PRODUCE DIFFERENT MAJORITY VERDICTS.

Family	N	RC=YES	RC=NO	Reversed
travel_noise	10	10	0	3
maintenance_window	8	3	5	3
failed_stuffing	8	0	8	0
legitimate_peak	8	8	0	0
decoy_misdirection	10	10	0	0
Total	44	31	13	6

TABLE VIII

S15 ABLATION: FIVE RUNS PER CONDITION, SAME MODEL AND TIMELINE.

Condition	Runs	Verdicts	Majority
With rule-alert context	5	YES $\times$ 5	YES (wrong)
Without rule-alert context	5	NO $\times$ 5	NO (correct)

travel” alternative) — both outside the validator’s scope and scored qualitatively.

Run-to-run consistency. A separate variance probe runs the LLM five times on each of a 22-scenario stratified subset (two per family across the holdout, plus the two calibration failure cases S14 and S15): 110 calls in total at temperature 0.1. Across all 110 runs, no scenario flipped verdict (per-scenario flip rate 0%, Fleiss’ $\kappa = 1.000$, category split 85 YES / 25 NO / 0 INSUFFICIENT). At the production temperature the model is therefore deterministic at the verdict level on the corpus we measured — which means the false-positive behaviour described above is a stable property of the model on these inputs, not a sampling artefact that disappears with multiple draws.

VIII. DISCUSSION AND LIMITATIONS

What the LLM adds. On attack scenarios the LLM contributes essentially perfect recall (100% on the 56 attack-labeled holdouts) where the rule engine reaches only 69.6%. The synthesis advantage is in cross-time-window aggregation no rule encodes (`scope_creep`: rules 0/12, Gemma 12/12), cross-source pattern reading (`session_hijack`: rules 5/10, Gemma 10/10), and contextual interpretation of administrative actions (`maintenance_window`: rules 0/8, Gemma 5/8 — reading the ticket and role to downgrade what would otherwise look like a critical pattern). None of this is beyond a richer rule set in principle; the grounded LLM provides it without an analyst enumerating every cross-window pattern in advance, and without claims that cannot be tied to events.

Where rules still matter. On benign scenarios rules outperform the LLM by 20 percentage points (70.5% vs 50.0%), and the gap is largest on hard-benign families designed to produce alert load (61.8% vs 38.2%). Rules are deterministic, cheap, continuously runnable, and auditable; they also produce alert identifiers the LLM can cite. The architectural reading

is therefore *rules-and-LLM as complements, not LLM-after-rules*: routing decisions should depend on the family of activity observed. Specifically, the LLM-as-triage layer pays off on the attack-recall axis but is not safe to deploy autonomously where false positives on legitimate-but-noisy activity carry cost. Countermeasures follow: confidence-weighted alert presentation, two-stage prompting (score alerts before rendering a verdict), a deployed counterfactual no-rule-context check (which detects the S15-class failure exactly), and an asymmetric review threshold that escalates the LLM’s NO (high-information) but down-weights its YES on benign-family events.

Grounding is necessary, not sufficient. S14 shows the validator can guarantee that cited events exist, are ordered, and name real actors — while the conclusion misattributes the attack. Evidence-grounded output is a *candidate* verdict, chain, and suspect for analyst review, consistent with how analysts already use LLMs [24]. The deployment posture is post-incident triage assistance (after-action reports, audit response, tier-1 summarization), not real-time blocking or autonomous attribution; the open-weight in-boundary serving property is hygiene for an assistant, but would be a liability for an autonomous detector whose failure modes the operator cannot inspect [15].

Limitations. (i) *Synthetic scenarios plus a partial third-party replay*: 15 calibration scenarios are author-designed and 100 holdout scenarios are generator-created from a committed parameter spec under a fixed seed; both are synthetic. The generator-based holdout addresses designer bias (parameters are auditable; the author never sees or hand-edits individual scenarios before scoring) and the CERT r4.2 replay (Section VII-D) adds 35 third-party windows where neither the corpus nor the labels were touched by the authors. Five additional CERT windows were lost to a transient endpoint outage and not synthesised, and on the CERT inputs the model returned Markdown rather than JSON in 34 of 35 windows, so verdicts there rest on prose extraction and the structured citation validator could not be applied at scale (Section VII-D); the CERT result should therefore be read as a verdict-level recall/precision finding, not a grounding result. LANL [44] and DARPA OpTC [45] replays are next; the LANL adapter exists in `app/ingestion/adapters/lanl_auth.py`; the OpTC adapter is a skeleton awaiting ground-truth windowing. (ii) *Single-model evaluation*: all LLM results are from a single open-weight Gemma deployment; the systematic over-classification of hard-benign scenarios may be a property of this model rather than of grounded LLM triage in general, and cannot be separated without multi-model replication [41], [42]. (iii) *Statistical scope and power*: the holdout reaches $n=100$, so exact 95% intervals for the headline are narrow (rules 70.0% [60.0, 78.8]; Gemma 78.0% [68.6, 85.7]) and the paired McNemar improvement on overall accuracy is not significant ($p=0.243$); the LLM’s attack-recall advantage is statistically established ($p<0.001$), and its benign-precision deficit is borderline ($p=0.064$). Run-to-run non-determinism remains a recognised forensic concern [29], [30], though at our deployed temperature of 0.1 the model was verdict-

deterministic on every scenario tested in the variance probe (Section VII-F; 110 runs, Fleiss’ $\kappa = 1.000$). The extended rule-context ablation (Section VII-F; 440 calls across 44 hard-benign and decoy scenarios) shows the S15 amplification effect generalises only partially (6 reversals out of 44). Stress trials remain $N=3$. (iv) *Coarse constructs*: binary verdict accuracy proxies investigative usefulness poorly, and step F_1 is sensitive to label naming; an analyst usefulness study is the missing instrument. (v) *Validator scope*: causal overclaim, missing alternatives, and wrong-suspect-with-real-evidence are not mechanically detected; volume and temporal checks were never triggered even at $n=115$, so their behaviour is unmeasured. The evaluation also used an external endpoint (acceptable only because data is synthetic); the in-boundary path is interface-validated, not exercised.

IX. FUTURE DIRECTIONS

Five directions follow directly from the limitations above. **(1) Multi-model replication** is the highest priority: repeating the holdout and CERT runs on Llama and Mistral [41], [42] would establish whether the benign false-positive prior is a property of grounded LLM triage or specific to the evaluated model. **(2) Real-data replay** on LANL [44] and DARPA OpTC [45] via the released adapters, trading exact ground truth for ecological validity, and completing the five CERT windows lost to the endpoint outage. **(3) Multi-suspect hypothesis tracking**, the direct S14 countermeasure: require the model to enumerate candidate actors with evidence for and against each before committing to a suspect [36]. **(4) A calibrated rule-context handler** that down-weights the LLM YES verdict on hard-benign families and applies the asymmetric review threshold proposed in Section VIII — the holdout’s main failure mode. **(5) Claim-level interpretive-grounding validation**, approximating atomic-fact verification over structured events [37] and combined with N -run self-consistency aggregation [39], plus an analyst usefulness study to replace the coarse verdict-accuracy construct.

X. CONCLUSION

This paper compared a transparent twelve-rule baseline and an evidence-grounded open-weight Gemma model over the same normalized seven-source private-cloud event schema, with every LLM claim required to cite event identifiers and audited by a deterministic seven-check validator. The 115-scenario corpus splits into 15 author-designed calibration scenarios and 100 generator-created holdout scenarios sampled deterministically from a committed parameter spec to limit designer bias. On the holdout the rule baseline reached 70.0% verdict accuracy [60.0, 78.8] and the LLM 78.0% [68.6, 85.7]; the paired improvement is not significant under McNemar’s exact test ($p=0.243$). The result splits sharply by label: on the 56 attack-labeled holdout scenarios the LLM reached 100.0% recall [93.6, 100.0] against 69.6% for rules, an effect significant at $p<0.001$; on the 44 benign scenarios the direction reversed, with rules 70.5% versus LLM 50.0%, and on the 34 hard-benign scenarios the LLM fell to 38.2%. Across all 115 scenarios

2067 of 2068 event-identifier references resolved to real events (99.95% citation validity), 114 of 115 scenarios had zero invalid citations, and no fabricated event identifier was observed. The contribution this evaluation establishes is the methodology — per-claim citation enforcement with deterministic validation, three separately scored correctness axes, a parameter-driven holdout corpus addressing designer bias, and statistically powered analysis — together with the directional finding that grounded LLM triage contributes substantial attack-recall over a rule baseline but introduces a real false-positive cost on legitimate-but-noisy activity that current grounding validation does not catch. Citation validity does not imply interpretive correctness, and the LLM’s YES verdict on hard-benign families is not neutral evidence. The supported role for LLMs in forensic investigation is bounded reasoning over structured evidence — as a high-recall first-pass triage layer, validated mechanically, characterized by failure mode, and reviewed by a human analyst — rather than autonomous detection or attribution.

REFERENCES

- [1] J. Glasser and B. Lindauer, “Bridging the gap: A pragmatic approach to generating insider threat data,” in *Proc. 2013 IEEE Security and Privacy Workshops (SPW)*, 2013, pp. 98–104.
- [2] M. Herman, M. Iorga, A. M. Salim, R. H. Jackson, M. Hurst, R. Leo, R. Lee, N. Landreville, A. Mishra, Y. Wang, and R. Sardinias, “NIST cloud computing forensic science challenges,” National Institute of Standards and Technology, Tech. Rep. NISTIR 8006, 2020.
- [3] K. Ruan, J. Carthy, T. Kechadi, and I. Baggili, “Cloud forensics definitions and critical criteria for cloud forensic capability: An overview of survey results,” *Digital Investigation*, vol. 10, no. 1, pp. 34–43, 2013.
- [4] K. Kent, S. Chevalier, T. Grance, and H. Dang, “Guide to integrating forensic techniques into incident response,” National Institute of Standards and Technology, Tech. Rep. NIST SP 800-86, 2006.
- [5] S. Tariq, M. B. Chhetri, S. Nepal, and C. Paris, “Alert fatigue in security operations centres: Research challenges and opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, pp. 224:1–224:38, 2025.
- [6] T. Ban, T. Takahashi, S. Ndichu, and D. Inoue, “Breaking alert fatigue: AI-assisted SIEM framework for effective incident response,” *Applied Sciences*, vol. 13, no. 11, p. 6610, 2023.
- [7] A. Nadler, A. Aminov, and A. Shabtai, “Detection of malicious and low throughput data exfiltration over the DNS protocol,” *Computers & Security*, vol. 80, pp. 36–53, 2019.
- [8] A. Habibzadeh, F. Feyzi, and R. Ebrahimi Atani, “Large language models for security operations centers: A comprehensive survey,” 2025.
- [9] A. Wickramasekara, F. Breiteringer, and M. Scanlon, “Exploring the potential of large language models for improving digital forensic investigation efficiency,” *Forensic Science International: Digital Investigation*, vol. 52, p. 301859, 2025.
- [10] L. Huang, W. Yu, W. Ma, W. Zhong, Z. Feng, H. Wang, Q. Chen, W. Peng, X. Feng, B. Qin, and T. Liu, “A survey on hallucination in large language models: Principles, taxonomy, challenges, and open questions,” *ACM Transactions on Information Systems*, vol. 43, no. 2, pp. 42:1–42:55, 2025.
- [11] M. Scanlon, F. Breiteringer, C. Hargreaves, J.-N. Hilgert, and J. Sheppard, “ChatGPT for digital forensic investigation: The good, the bad, and the unknown,” *Forensic Science International: Digital Investigation*, vol. 46, p. 301609, 2023.

- [12] Gemma Team, “Gemma: Open models based on Gemini research and technology,” 2024.
- [13] F. Y. Loumach, M. C. Ghanem, and M. A. Ferrag, “GenDFIR: Advancing cyber incident timeline analysis through retrieval-augmented generation and large language models,” *Computers*, vol. 14, no. 2, p. 67, 2025.
- [14] W. Cheng, T. Zhu, S. Jing, J.-P. Mei, M. Ma, J. Jin, and Z. Weng, “OMNISEC: LLM-driven provenance-based intrusion detection via retrieval-augmented behavior prompting,” 2025.
- [15] R. Sommer and V. Paxson, “Outside the closed world: On using machine learning for network intrusion detection,” in *Proc. 2010 IEEE Symposium on Security and Privacy (S&P)*, 2010, pp. 305–316.
- [16] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, “Dos and don’ts of machine learning in computer security,” in *Proc. 31st USENIX Security Symposium*, 2022, pp. 3971–3988.
- [17] C. Sharma, “Retrieval-augmented generation: A comprehensive survey of architectures, enhancements, and robustness frontiers,” 2025.
- [18] J. Dykstra and A. T. Sherman, “Design and implementation of FROST: Digital forensic tools for the OpenStack cloud computing platform,” *Digital Investigation*, vol. 10, pp. S87–S95, 2013.
- [19] K. Gudjonsson, “Mastering the super timeline with log2timeline,” SANS Institute Reading Room / GIAC GCFA Gold Paper, 2010. [Online]. Available: <https://www.sans.org/white-papers/33438/>
- [20] S. T. King and P. M. Chen, “Backtracking intrusions,” in *Proc. 19th ACM Symposium on Operating Systems Principles (SOSP)*, 2003, pp. 223–236.
- [21] S. M. Milajerdi, R. Gjomemo, B. Eshete, R. Sekar, and V. N. Venkatakrishnan, “HOLMES: Real-time APT detection through correlation of suspicious information flows,” in *Proc. 2019 IEEE Symposium on Security and Privacy (S&P)*, 2019, pp. 1137–1152.
- [22] M. Du, F. Li, G. Zheng, and V. Srikumar, “DeepLog: Anomaly detection and diagnosis from system logs through deep learning,” in *Proc. 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2017, pp. 1285–1298.
- [23] J. Qi, S. Huang, Z. Luan, C. Fung, H. Yang, and D. Qian, “LogGPT: Exploring ChatGPT for log-based anomaly detection,” 2023.
- [24] R. Singh, S. Tariq, F. Jalalvand, M. B. Chhetri, S. Nepal, C. Paris, and M. Lochner, “LLMs in the SOC: An empirical study of human–AI collaboration in security operations centres,” 2025.
- [25] B. Wei, Y. S. Tay, H. Liu, J. Pan, K. Luo, Z. Zhu, and C. Jordan, “CORTEX: Collaborative LLM agents for high-stakes alert triage,” 2025.
- [26] X. Cadet, A. V. Singh, H. Mamania, E. Koh, A. Fitts, D. Van Bruggen, S. Boboila, P. Chin, and A. Oprea, “Retrieval-augmented LLMs for security incident analysis,” 2026.
- [27] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and philosophy,” The MITRE Corporation, Tech. Rep. PR-18-0944-11, 2018. [Online]. Available: <https://attack.mitre.org/resources/>
- [28] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection,” in *Proc. 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, 2023, pp. 79–90.
- [29] Z. Yin, Z. Wang, W. Xu, J. Zhuang, P. Mozumder, A. Smith, and W. Zhang, “Digital forensics in the age of large language models,” 2025.
- [30] H. Studiawan, F. Breiting, and M. Scanlon, “Towards a standardized methodology and dataset for evaluating LLM-based digital forensic timeline analysis,” *Forensic Science International: Digital Investigation*, 2025, arXiv:2505.03100.
- [31] B. Cherif, T. Bisztray, R. A. Dubniczky, A. Aldahmani, S. Alshehhi, and N. Tihanyi, “DFIR-Metric: A benchmark dataset for evaluating large language models in digital forensics and incident response,” in *Proc. 32nd International Conference on Neural Information Processing (ICONIP 2025)*, LNCS vol. 16309. Springer, 2025.
- [32] B. Sharma, J. Ghawaly, K. McCleary, A. M. Webb, and I. Baggili, “ForensicLLM: A local large language model for digital forensics,” *Forensic Science International: Digital Investigation*, p. 301872, 2025.
- [33] D. Alharthi and R. Yasaei, “LLM-powered automated cloud forensics: From log analysis to investigation,” in *Proc. 18th IEEE International Conference on Cloud Computing (CLOUD)*, 2025.
- [34] Z. Xu, S. Jain, and M. Kankanhalli, “Hallucination is inevitable: An innate limitation of large language models,” 2024.
- [35] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N. Goyal, H. Küttler, M. Lewis, W. tau Yih, T. Rocktäschel, S. Riedel, and D. Kiela, “Retrieval-augmented generation for knowledge-intensive NLP tasks,” in *Advances in Neural Information Processing Systems*, vol. 33, 2020, pp. 9459–9474.
- [36] B. Bohnet, V. Q. Tran, P. Verga, R. Aharoni, D. Andor, L. Baldini Soares, J. Eisenstein, K. Ganchev, J. Herzig, K. Hui, T. Kwiatkowski, J. Ma, J. Ni, T. Schuster, W. W. Cohen, M. Collins, D. Das, D. Metzler, S. Petrov, and K. Webster, “Attributed question answering: Evaluation and modeling for attributed large language models,” 2022.
- [37] S. Min, K. Krishna, X. Lyu, M. Lewis, W. tau Yih, P. W. Koh, M. Iyyer, L. Zettlemoyer, and H. Hajishirzi, “FactScore: Fine-grained atomic evaluation of factual precision in long form text generation,” in *Proc. 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2023, pp. 12 076–12 100.
- [38] S. Geng, M. Josifoski, M. Peyrard, and R. West, “Grammar-constrained decoding for structured NLP tasks without finetuning,” in *Proc. 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2023, pp. 10 932–10 952.
- [39] X. Wang, J. Wei, D. Schuurmans, Q. V. Le, E. H. Chi, S. Narang, A. Chowdhery, and D. Zhou, “Self-consistency improves chain of thought reasoning in language models,” in *Proc. 11th International Conference on Learning Representations (ICLR)*, 2023.
- [40] M. Turpin, J. Michael, E. Perez, and S. R. Bowman, “Language models don’t always say what they think: Unfaithful explanations in chain-of-thought prompting,” in *Advances in Neural Information Processing Systems*, vol. 36, 2023.
- [41] H. Touvron, L. Martin, K. Stone *et al.*, “Llama 2: Open foundation and fine-tuned chat models,” 2023.
- [42] A. Q. Jiang, A. Sablayrolles, A. Mensch, C. Bamford, D. S. Chaplot, D. de las Casas *et al.*, “Mistral 7B,” 2023.
- [43] A. Tuor, S. Kaplan, B. Hutchinson, N. Nichols, and S. Robinson, “Deep learning for unsupervised insider threat detection in structured cybersecurity data streams,” AAAI Workshop on Artificial Intelligence for Cyber Security (AICS), 2017.
- [44] A. D. Kent, “Comprehensive, multi-source cyber-security events data set,” Los Alamos National Laboratory, 2015.
- [45] M. M. Anjum, S. Iqbal, and B. Hamelin, “Analyzing the usefulness of the DARPA OpTC dataset in cyber threat detection research,” in *Proc. 26th ACM Symposium on Access Control Models and Technologies (SACMAT)*, 2021, pp. 27–32.
- [46] J. Flynt, “OrgForge-IT: A verifiable synthetic benchmark for LLM-based insider threat detection,” 2026.
- [47] Open Cybersecurity Schema Framework Contributors, “Open cybersecurity schema framework (OCSF) schema,” Open-source specification, 2022. [Online]. Available: <https://github.com/ocsf/ocsf-schema>